Secure Skies, Inc. - Cyber Risk Modeling

Stu's Determined Experienced Network Technicians LLC (StuDENT LLC)

Group 8
Arturo Bohuchot, Porter Geddes, Viknesh Pathmarajah, Supavit Pitaknarongphorn

16 April 2026

Table of Contents

Table of Contents **1**
1. Executive Summary **3**
2. CMMC Level 2 ..... **4**
2.1. Controlled Unclassified Information (CUI) 4
2.2. Assessment Types and Certification Paths 4
2.3. Assessment Methodology: The EIT Framework 4
2.4. Scoring and Assessment Findings 5
2.5. Assessment 5
3. Mitre Att&ck Framework **19**
3.1. What are we working on? 19
3.1.1. Assemble your team 19
3.1.1.1. Gather relevant documentation 19
Documents of Interest 19
3.1.1.2. Identify key stakeholders 20
Pre-mortem 20
Responsible, Accountable, Consulted, and Informed (RACI) Matrix 21
3.1.2. Mission Decomposition 21
3.1.2.1. Map the mission objectives 21
Mission Statement 21
Mission Objectives 22
3.1.2.2. Identify Operational Tasks (Cross-Functional Flow Chart) 22
Cross-Functional Flow Chart and CI/CD Architecture 22
3.1.3. System Decomposition 22
3.1.3.1. Develop a Data Flow Diagram (DFD) of your system 22
Data Flow Diagram 22
3.1.3.2. Determine which system functions are associated with distinct operational tasks 23
System Mapping 23
3.1.4. Identification of critical assets 23
Critical Assets 23
3.1.5. Open Source Intelligence Report 24
3.1.6. Asset Classification 24
3.1.7. Software Development and Operations Asset List 24
3.1.8. Concept Map 24
3.1.9. Master Evidence Log 25
3.2. What could go wrong? 25
3.2.1. STRIDE 25
3.2.2. FAIR 25
3.2.3. STIX 26
3.2.4. Monte Carlo Simulation 26

3.3. What are we going to do about it?..... 26
3.3.1. Post Implementation Controls CI/CD Diagram..... 27
3.3.2. Additional Documents for Reference..... 27
4. Dashboard..... 28

1. Executive Summary

Secure Skies, Inc., supported by StuDENT LLC, conducted a comprehensive cyber risk modeling and compliance assessment to evaluate the organization's readiness for Cybersecurity Maturity Model Certification (CMMC) Level 2. This effort focused on protecting Controlled Unclassified Information (CUI), strengthening cybersecurity posture, and aligning with Department of Defense (DoD) requirements under NIST SP 800-171.

The assessment identified that Secure Skies operates in a high-risk environment due to its role in developing advanced counter-drone technologies and reliance on interconnected systems, third-party vendors, and cloud-based infrastructure. Critical mission objectives—including protection of intellectual property, integrity of CI/CD pipelines, financial security, and supply chain resilience—are highly susceptible to cyber threats such as credential compromise, phishing, supply chain attacks, and nation-state targeting.

Using structured methodologies including the MITRE ATT&CK framework, STRIDE analysis, and the FAIR risk model, the team identified key vulnerabilities across technical, operational, and human domains. Notable risks include exposed credentials, insecure external services, lack of enforcement of email security controls, and insufficient authentication mechanisms. These weaknesses contribute to an estimated Annualized Loss Expectancy (ALE) of approximately $3.97 million, with worst-case scenarios exceeding $20 million.

The organization's current compliance posture is significantly below CMMC Level 2 requirements, with gaps spanning all 14 security domains and 110 required practices. However, the analysis also demonstrates that targeted investments in security controls can yield substantial risk reduction. A prioritized 18-month remediation roadmap was developed to guide Secure Skies toward approximately 95% compliance. This plan emphasizes early implementation of high-impact, low-cost controls such as credential rotation, multi-factor authentication, and system security documentation, followed by infrastructure improvements including network segmentation, endpoint detection and response (EDR), and centralized logging.

By adopting a risk-informed, phased approach, Secure Skies can reduce over 60% of its cyber risk within the initial months while maintaining cost efficiency. Successful execution of this strategy will position the organization to achieve CMMC Level 2 certification, enhance resilience against advanced threats, and secure eligibility for future DoD contracts.

2. CMMC Level 2[1]

The Cybersecurity Maturity Model Certification (CMMC) Level 2 program establishes the regulatory framework for the preparation and conduct of assessments as mandated by 32 CFR § 170.16 (Self-assessments) and 32 CFR § 170.17 (Certification assessments). Level 2 is purpose-built to ensure the protection of Controlled Unclassified Information (CUI) within the Defense Industrial Base (DIB). This level aligns directly with the security requirements of NIST SP 800-171 Revision 2. As a Lead Auditor, it is critical to note that certification at each CMMC level occurs independently; achieving Level 2 does not grant "automatic" compliance with other levels, nor does it waive the rigorous evidence requirements for its 110 security requirements.

2.1. Controlled Unclassified Information (CUI)

Per 32 CFR § 2002.4(h), CUI is information the Government creates or possesses, or that an entity creates or possesses for or on behalf of the Government, that a law, regulation, or Government-wide policy requires or permits an agency to handle using safeguarding or dissemination controls. This excludes classified information and information maintained by a non-executive branch entity in its own systems that was not created or possessed for an executive branch agency.

2.2. Assessment Types and Certification Paths

Organizations must identify their specific contractual requirements to determine which of the two Level 2 assessment paths is required: Self-assessment or Level 2 Certification Assessment. Both paths utilize NIST SP 800-171A as the authoritative evaluation standard. The Organization Seeking Assessment (OSA) is the general term for any entity undergoing evaluation. When an OSA specifically seeks a third-party evaluation from an accredited body, it is referred to as the Organization Seeking Certification (OSC). Assessors cannot begin an engagement without a finalized Assessment Scope defined in accordance with 32 CFR § 170.19. This scope identifies the set of all assets in the OSA's environment that will be assessed against CMMC security requirements and serves as the mandatory boundary for all evidence collection.

2.3. Assessment Methodology: The EIT Framework

To verify and validate that an OSA meets CMMC requirements, assessors must utilize three mandatory assessment methods. While "Examine" and "Interview" provide context, the Test method is the deciding factor in most assessment objectives, as it demonstrates what has actually been implemented versus what is merely documented or claimed.

- Examine: Reviewing, inspecting, observing, or analyzing assessment objects to obtain evidence.
- Interview: Discussions with personnel to facilitate understanding or achieve clarification.
- Test: Exercising assessment objects under specified conditions to compare actual behavior with expected behavior.

Assessors evaluate four specific types of assessment objects:

- Specifications: The document-based artifacts (e.g., policies, procedures, security plans, security requirements, functional specifications, architectural designs) associated with a system.
- Mechanisms: The specific hardware, software, or firmware safeguards employed within a system.
- Activities: The protection-related actions supporting a system that involve people (e.g., conducting system backup operations, exercising a contingency plan, and monitoring network traffic).
- Individuals: People, or groups of individuals, applying the specifications, mechanisms, or activities described above.

[1] CMMC Assessment Guide: Level 2
https://dodcio.defense.gov/Portals/0/Documents/CMMC/AssessmentGuideL2v2.pdf

Evidence used during the "Examine" method must be in its final form; drafts of policies or documentation are strictly ineligible. Common evidence types include:

- Policy, process, and procedure documents
- Training materials
- Plans and planning documents
- System, network, and data flow diagrams

2.4. Scoring and Assessment Findings

Assessing a CMMC requirement results in one of three findings: MET, NOT MET, or NOT APPLICABLE (N/A). A requirement is MET only when all applicable assessment objectives are satisfied. Assessors capture results at the assessment objective level. Because a single security requirement is composed of multiple objectives, any single objective found to be NOT MET results in the failure of the entire security requirement. There is no partial credit; an OSA must satisfy every objective to secure the associated points for that requirement.

2.5. Assessment

CMMC Level 2 consists of 110 security requirements, each containing a list of security objectives the system must meet. These security requirements are categorized into 14 security domains, logically grouped to address different aspects of the control environment.

- ☐ 1. Access Control (AC)
  - ☑ AC.L2-3.1.1 – Authorized Access Control [CUI Data]: Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).
    - ☑ [a] authorized users are identified
    - ☑ [b] processes acting on behalf of authorized users are identified
    - ☑ [c] devices (and other systems) authorized to connect to the system are identified
    - ☑ [d] system access is limited to authorized users
    - ☑ [e] system access is limited to processes acting on behalf of authorized users
    - ☑ [f] system access is limited to authorized devices (including other systems)
  - ☐ AC.L2-3.1.2 – Transaction & Function Control: Limit system access to the types of transactions and functions that authorized users are permitted to execute.
    - ☐ [a] the types of transactions and functions that authorized users are permitted to execute are defined
    - ☐ [b] system access is limited to the defined types of transactions and functions for authorized users
  - ☐ AC.L2-3.1.3 – Control CUI Flow: Control the flow of CUI in accordance with approved authorizations.
    - ☐ [a] information flow control policies are defined
    - ☐ [b] methods and enforcement mechanisms for controlling the flow of CUI are defined
    - ☐ [c] designated sources and destinations for CUI within the system and between interconnected systems are identified
    - ☐ [d] authorizations for controlling the flow of CUI are defined
    - ☐ [e] approved authorizations for controlling the flow of CUI are enforced
  - ☐ AC.L2-3.1.4 – Separation of Duties: Separate the duties of individuals to reduce the risk of malevolent activity without collusion.
    - ☐ [a] the duties of individuals requiring separation are defined

- [ ] [b] responsibilities for duties that require separation are assigned to separate individuals
- [ ] [c] access privileges that enable individuals to exercise the duties that require separation are granted to separate individuals

- [ ] AC.L2-3.1.5 – Least Privilege: Employ the principle of least privilege, including for specific security functions and privileged accounts.
  - [ ] [a] privileged accounts are identified
  - [ ] [b] access to privileged accounts is authorized in accordance with the principle of least privilege
  - [ ] [c] security functions are identified
  - [ ] [d] access to security functions is authorized in accordance with the principle of least privilege
- [ ] AC.L2-3.1.6 – Non-Privileged Account Use: Use non-privileged accounts or roles when accessing nonsecurity functions.
  - [ ] [a] nonsecurity functions are identified
  - [ ] [b] users are required to use non-privileged accounts or roles when accessing nonsecurity functions
- [ ] AC.L2-3.1.7 – Privileged Functions: Prevent non-privileged users from executing privileged functions and capture the execution of such functions in audit logs.
  - [ ] [a] privileged functions are defined
  - [ ] [b] non-privileged users are defined
  - [ ] [c] non-privileged users are prevented from executing privileged functions
  - [ ] [d] the execution of privileged functions is captured in audit logs
- [ ] AC.L2-3.1.8 – Unsuccessful Logon Attempts: Limit unsuccessful logon attempts.
  - [ ] [a] the means of limiting unsuccessful logon attempts is defined
  - [ ] [b] the defined means of limiting unsuccessful logon attempts is implemented
- [ ] AC.L2-3.1.9 – Privacy & Security Notices: Provide privacy and security notices consistent with applicable CUI rules.
  - [ ] [a] privacy and security notices required by CUI-specified rules are identified, consistent, and associated with the specific CUI category
  - [ ] [b] privacy and security notices are displayed
- [ ] AC.L2-3.1.10 – Session Lock: Use session lock with pattern-hiding displays to prevent access and viewing of data after a period of inactivity.
  - [ ] [a] the period of inactivity after which the system initiates a session lock is defined
  - [ ] [b] access to the system and viewing of data is prevented by initiating a session lock after the defined period of inactivity
  - [ ] [c] previously visible information is concealed via a pattern-hiding display after the defined period of inactivity
- [ ] AC.L2-3.1.11 – Session Termination: Terminate (automatically) a user session after a defined condition.
  - [ ] [a] conditions requiring a user session to terminate are defined
  - [ ] [b] a user session is automatically terminated after any of the defined conditions occur
- [ ] AC.L2-3.1.12 – Control Remote Access: Monitor and control remote access sessions.
  - [ ] [a] remote access sessions are permitted
  - [ ] [b] the types of permitted remote access are identified
  - [ ] [c] remote access sessions are controlled
  - [ ] [d] remote access sessions are monitored

- [x] AC.L2-3.1.13 – Remote Access Confidentiality: Employ cryptographic mechanisms to protect the confidentiality of remote access sessions.
  - [x] [a] cryptographic mechanisms to protect the confidentiality of remote access sessions are identified
  - [x] [b] cryptographic mechanisms to protect the confidentiality of remote access sessions are implemented
- [ ] AC.L2-3.1.14 – Remote Access Routing: Route remote access via managed access control points.
  - [ ] [a] managed access control points are identified and implemented
  - [ ] [b] remote access is routed through managed network access control points
- [ ] AC.L2-3.1.15 – Privileged Remote Access: Authorize remote execution of privileged commands and remote access to security-relevant information.
  - [ ] [a] privileged commands authorized for remote execution are identified;
  - [ ] [b] security-relevant information authorized to be accessed remotely is identified;
  - [ ] [c] the execution of the identified privileged commands via remote access is authorized;
  - [ ] [d] access to the identified security-relevant information via remote access is authorized
- [x] AC.L2-3.1.16 – Wireless Access Authorization: Authorize wireless access prior to allowing such connections.
  - [x] [a] wireless access points are identified
  - [x] [b] wireless access is authorized prior to allowing such connections
- [ ] AC.L2-3.1.17 – Wireless Access Protection: Protect wireless access using authentication and encryption.
  - [ ] [a] wireless access to the system is protected using authentication
  - [ ] [b] wireless access to the system is protected using encryption
- [ ] AC.L2-3.1.18 – Mobile Device Connection: Control connection of mobile devices.
  - [ ] [a] mobile devices that process, store, or transmit CUI are identified;
  - [ ] [b] mobile device connections are authorized; and
  - [ ] [c] mobile device connections are monitored and logged.
- [ ] AC.L2-3.1.19 – Encrypt CUI on Mobile: Encrypt CUI on mobile devices and mobile computing platforms.
  - [ ] [a] mobile devices and mobile computing platforms that process, store, or transmit CUI are identified
  - [ ] [b] encryption is employed to protect CUI on identified mobile devices and mobile computing platforms
- [ ] AC.L2-3.1.20 – External Connections [CUI Data]: Verify and control/limit connections to and use of external systems.
  - [ ] [a] connections to external systems are identified
  - [ ] [b] the use of external systems is identified
  - [ ] [c] connections to external systems are verified
  - [ ] [d] the use of external systems is verified
  - [ ] [e] connections to external systems are controlled/limited
  - [ ] [f] the use of external systems is controlled/limited
- [ ] AC.L2-3.1.21 – Portable Storage Use: Limit use of portable storage devices on external systems.
  - [ ] [a] the use of portable storage devices containing CUI on external systems is identified and documented
  - [ ] [b] limits on the use of portable storage devices containing CUI on external systems are defined

- [ ] [c] the use of portable storage devices containing CUI on external systems is limited as defined.
- [ ] AC.L2-3.1.22 – Control Public Information [CUI Data]: Control CUI posted or processed on publicly accessible systems.
  - [ ] [a] individuals authorized to post or process information on publicly accessible systems are identified
  - [ ] [b] procedures to ensure CUI is not posted or processed on publicly accessible systems are identified
  - [ ] [c] a review process is in place prior to posting of any content to publicly accessible systems
  - [ ] [d] content on publicly accessible systems is reviewed to ensure that it does not include CUI
  - [ ] [e] mechanisms are in place to remove and address improper posting of CUI

- [ ] 2. Awareness and Training (AT)
  - [ ] AT.L2-3.2.1 – Role-Based Risk Awareness: Ensure that managers, systems administrators, and users of organizational systems are made aware of the security risks associated with their activities and of the applicable policies, standards, and procedures related to the security of those systems.
    - [ ] [a] security risks associated with organizational activities involving CUI are identified
    - [ ] [b] policies, standards, and procedures related to the security of the system are identified
    - [ ] [c] managers, systems administrators, and users are made aware of the security risks associated with their activities
    - [ ] [d] managers, systems administrators, and users are made aware of applicable policies, standards, and procedures
  - [ ] AT.L2-3.2.2 – Role-Based Training: Ensure that personnel are trained to carry out their assigned information security-related duties and responsibilities.
    - [ ] [a] information security-related duties, roles, and responsibilities are defined
    - [ ] [b] information security-related duties, roles, and responsibilities are assigned to designated personnel
    - [ ] [c] personnel are adequately trained to carry out their assigned duties
  - [ ] AT.L2-3.2.3 – Insider Threat Awareness: Provide security awareness training on recognizing and reporting potential indicators of insider threat.
    - [ ] [a] potential indicators associated with insider threats are identified
    - [ ] [b] security awareness training on recognizing and reporting potential indicators of insider threat is provided

- [ ] 3. Audit and Accountability (AU)
  - [ ] AU.L2-3.3.1 – System Auditing: Create and retain system audit logs and records to the extent needed to enable the monitoring, analysis, investigation, and reporting of unlawful or unauthorized system activity.
    - [ ] [a] audit logs needed (event types to be logged) are specified
    - [ ] [b] the content of audit records needed to support monitoring and investigation is defined
    - [ ] [c] audit records are created (generated)
    - [ ] [d] audit records contain the defined content
    - [ ] [e] retention requirements for audit records are defined
    - [ ] [f] audit records are retained as defined
  - [ ] AU.L2-3.3.2 – User Accountability: Ensure that the actions of individual system users can be uniquely traced to those users so they can be held accountable for their actions.

- [ ] [a] the content of audit records needed to uniquely trace users to their actions is defined
- [ ] [b] audit records contain the defined content

- [ ] AU.L2-3.3.3 – Event Review: Review and update logged events.
  - [ ] [a] a process for determining when to review logged events is defined;
  - [ ] [b] event types being logged are reviewed in accordance with the defined review process
  - [ ] [c] event types being logged are updated based on the review.
- [ ] AU.L2-3.3.4 – Audit Failure Alerting: Alert in the event of an audit logging process failure.
  - [ ] [a] personnel or roles to be alerted in the event of a logging failure are identified
  - [ ] [b] types of audit logging process failures for which alerts will be generated are defined
  - [ ] [c] identified personnel or roles are alerted in the event of a logging process failure
- [ ] AU.L2-3.3.5 – Audit Correlation: Correlate audit record review, analysis, and reporting processes for investigation and response to indications of unlawful, unauthorized, suspicious, or unusual activity.
  - [ ] [a] audit record review, analysis, and reporting processes for investigation of unlawful activity are defined
  - [ ] [b] defined audit record review, analysis, and reporting processes are correlated.
- [ ] AU.L2-3.3.6 – Reduction & Reporting: Provide audit record reduction and report generation to support on-demand analysis and reporting.
  - [ ] [a] an audit record reduction capability that supports on-demand analysis is provided
  - [ ] [b] a report generation capability that supports on-demand reporting is provided
- [x] AU.L2-3.3.7 – Authoritative Time Source: Provide a system capability that compares and synchronizes internal system clocks with an authoritative source to generate time stamps for audit records.
  - [x] [a] internal system clocks are used to generate time stamps
  - [x] [b] an authoritative source for clock synchronization is specified
  - [x] [c] internal system clocks are compared to and synchronized with the authoritative source
- [ ] AU.L2-3.3.8 – Audit Protection: Protect audit information and audit logging tools from unauthorized access, modification, and deletion.
  - [ ] [a] audit information is protected from unauthorized access
  - [ ] [b] audit information is protected from unauthorized modification
  - [ ] [c] audit information is protected from unauthorized deletion
  - [ ] [d] audit logging tools are protected from unauthorized access
  - [ ] [e] audit logging tools are protected from unauthorized modification
  - [ ] [f] audit logging tools are protected from unauthorized deletion
- [x] AU.L2-3.3.9 – Audit Management: Limit management of audit logging functionality to a subset of privileged users.
  - [x] [a] a subset of privileged users granted access to manage audit logging is defined
  - [x] [b] management of audit logging functionality is limited to the defined subset of privileged users

- [ ] 4. Configuration Management (CM)
  - [ ] CM.L2-3.4.1 – System Baselining: Establish and maintain baseline configurations and inventories of organizational systems (including hardware, software, firmware, and documentation) throughout the respective system development life cycles.

- [ ] [a] a baseline configuration is established
- [ ] [b] the baseline configuration includes hardware, software, firmware, and documentation
- [ ] [c] the baseline configuration is maintained throughout the system life cycle
- [ ] [d] a system inventory is established
- [ ] [e] the inventory includes hardware, software, firmware, and documentation
- [ ] [f] the inventory is maintained throughout the system life cycle

- [ ] CM.L2-3.4.2 – Security Configuration Enforcement: Establish and enforce security configuration settings for information technology products employed in organizational systems.
  - [ ] [a] security configuration settings are established and included in the baseline
  - [ ] [b] security configuration settings are enforced
- [ ] CM.L2-3.4.3 – System Change Management: Track, review, approve or disapprove, and log changes to organizational systems.
  - [ ] [a] changes to the system are tracked
  - [ ] [b] changes to the system are reviewed
  - [ ] [c] changes to the system are approved or disapproved
  - [ ] [d] changes to the system are logged
- [ ] CM.L2-3.4.4 – Security Impact Analysis: Analyze the security impact of changes prior to implementation.
  - [ ] [a] the security impact of changes to the system is analyzed prior to implementation.
- [ ] CM.L2-3.4.5 – Access Restrictions for Change: Define, document, approve, and enforce physical and logical access restrictions associated with changes to organizational systems.
  - [ ] [a] physical access restrictions for changes are defined
  - [ ] [b] physical access restrictions for changes are documented
  - [ ] [c] physical access restrictions for changes are approved
  - [ ] [d] physical access restrictions for changes are enforced
  - [ ] [e] logical access restrictions for changes are defined
  - [ ] [f] logical access restrictions for changes are documented
  - [ ] [g] logical access restrictions for changes are approved
  - [ ] [h] logical access restrictions for changes are enforced
- [ ] CM.L2-3.4.6 – Least Functionality: Employ the principle of least functionality by configuring organizational systems to provide only essential capabilities.
  - [ ] [a] essential system capabilities are defined based on least functionality
  - [ ] [b] the system is configured to provide only defined essential capabilities
- [ ] CM.L2-3.4.7 – Nonessential Functionality: Restrict, disable, or prevent the use of nonessential programs, functions, ports, protocols, and services.
  - [ ] [a] essential programs are defined;
  - [ ] [b] the use of nonessential programs is defined;
  - [ ] [c] the use of nonessential programs is restricted, disabled, or prevented as defined;
  - [ ] [d] essential functions are defined;
  - [ ] [e] the use of nonessential functions is defined;
  - [ ] [f] the use of nonessential functions is restricted, disabled, or prevented as defined;
  - [ ] [g] essential ports are defined;
  - [ ] [h] the use of nonessential ports is defined;

- [ ] [i] the use of nonessential ports is restricted, disabled, or prevented as defined;
- [ ] [j] essential protocols are defined;
- [ ] [k] the use of nonessential protocols is defined;
- [ ] [l] the use of nonessential protocols is restricted, disabled, or prevented as defined;
- [ ] [m] essential services are defined;
- [ ] [n] the use of nonessential services is defined; and
- [ ] [o] the use of nonessential services is restricted, disabled, or prevented as defined.

- [ ] CM.L2-3.4.8 – Application Execution Policy: Apply deny-by-exception (blacklisting) policy to prevent the use of unauthorized software or deny-all, permit-by-exception (whitelisting) policy to allow the execution of authorized software.
  - [ ] [a] a policy specifying whitelisting or blacklisting is defined
  - [ ] [b] allowed or denied software is specified
  - [ ] [c] whitelisting or blacklisting is implemented as specified
- [ ] CM.L2-3.4.9 – User-Installed Software: Control and monitor user-installed software.
  - [ ] [a] a policy for controlling user-installed software is established
  - [ ] [b] user-installed software is controlled based on the policy
  - [ ] [c] user-installed software is monitored

- [ ] 5. Identification and Authentication (IA)
  - [ ] IA.L2-3.5.1 – Identification [CUI Data]: Identify system users, processes acting on behalf of users, and devices.
    - [ ] [a] system users are identified
    - [ ] [b] processes acting on behalf of users are identified
    - [ ] [c] devices accessing the system are identified
  - [x] IA.L2-3.5.2 – Authentication [CUI Data]: Authenticate (or verify) the identities of users, processes, or devices, as a prerequisite to allowing access to organizational systems.
    - [x] [a] user identities are authenticated/verified as a prerequisite to access
    - [x] [b] process identities are authenticated/verified as a prerequisite to access
    - [x] [c] device identities are authenticated/verified as a prerequisite to access
  - [ ] IA.L2-3.5.3 – Multifactor Authentication: Use multifactor authentication for local and network access to privileged accounts and for network access to non-privileged accounts.
    - [ ] [a] privileged accounts are identified
    - [ ] [b] MFA is implemented for local access to privileged accounts
    - [ ] [c] MFA is implemented for network access to privileged accounts
    - [ ] [d] MFA is implemented for network access to non-privileged accounts
  - [ ] IA.L2-3.5.4 – Replay-Resistant Authentication: Employ replay-resistant authentication mechanisms for network access to privileged and non-privileged accounts.
    - [ ] [a] replay-resistant authentication mechanisms are implemented for network account access to privileged and non-privileged accounts.
  - [ ] IA.L2-3.5.5 – Identifier Reuse: Prevent reuse of identifiers for a defined period.
    - [ ] [a] a non-reuse period is defined
    - [ ] [b] reuse is prevented within the defined period
  - [ ] IA.L2-3.5.6 – Identifier Handling: Disable identifiers after a defined period of inactivity.
    - [ ] [a] a period of inactivity after which an identifier is disabled is defined
    - [ ] [b] identifiers are disabled after a defined period of inactivity
  - [x] IA.L2-3.5.7 – Password Complexity: Enforce a minimum password complexity and change of characters when new passwords are created.

- [x] [a] complexity requirements are defined
- [x] [b] character change requirements are defined
- [x] [c] complexity requirements are enforced during password creation
- [x] [d] character change requirements are enforced during password creation

- [ ] IA.L2-3.5.8 – Password Reuse: Prohibit password reuse for a specified number of generations.
  - [ ] [a] the number of generations for reuse prohibition is specified
  - [ ] [b] reuse is prohibited during the specified generations
- [ ] IA.L2-3.5.9 – Temporary Passwords: Allow temporary password use for system logons with an immediate change to a permanent password.
  - [ ] [a] immediate change to a permanent password is required upon logon
- [ ] IA.L2-3.5.10 – Cryptographically-Protected Passwords: Store and transmit only cryptographically-protected passwords.
  - [ ] [a] passwords are cryptographically protected in storage
  - [ ] [b] passwords are cryptographically protected in transit
- [ ] IA.L2-3.5.11 – Obscure Feedback: Obscure feedback of authentication information.
  - [ ] [a] authentication information is obscured during the process

- [ ] 6. Incident Response (IR)
  - [x] IR.L2-3.6.1 – Incident Handling: Establish an operational incident-handling capability for organizational systems that includes preparation, detection, analysis, containment, recovery, and user response activities.
    - [x] [a] an operational incident-handling capability is established;
    - [x] [b] the operational incident-handling capability includes preparation;
    - [x] [c] the operational incident-handling capability includes detection;
    - [x] [d] the operational incident-handling capability includes analysis;
    - [x] [e] the operational incident-handling capability includes containment;
    - [x] [f] the operational incident-handling capability includes recovery; and
    - [x] [g] the operational incident-handling capability includes user response activities.
  - [ ] IR.L2-3.6.2 – Incident Reporting: Track, document, and report incidents to designated officials and/or authorities both internal and external to the organization.
    - [ ] [a] incidents are tracked;
    - [ ] [b] incidents are documented;
    - [ ] [c] authorities to whom incidents are to be reported are identified;
    - [ ] [d] organizational officials to whom incidents are to be reported are identified;
    - [ ] [e] identified authorities are notified of incidents; and
    - [ ] [f] identified organizational officials are notified of incidents.
  - [ ] IR.L2-3.6.3 – Incident Response Testing: Test the organizational incident response capability.
    - [ ] [a] the incident response capability is tested
- [ ] 7. Maintenance (MA)
  - [x] MA.L2-3.7.1 – Perform Maintenance: Perform maintenance on organizational systems.
    - [x] [a] system maintenance is performed.
  - [ ] MA.L2-3.7.2 – System Maintenance Control: Provide controls on the tools, techniques, mechanisms, and personnel used to conduct system maintenance.
    - [ ] [a] tools used to conduct system maintenance are controlled;
    - [ ] [b] techniques used to conduct system maintenance are controlled;
    - [ ] [c] mechanisms used to conduct system maintenance are controlled; and
    - [ ] [d] personnel used to conduct system maintenance are controlled.

- [ ] MA.L2-3.7.3 – Equipment Sanitization: Ensure equipment removed for off-site maintenance is sanitized of any CUI.
    - [ ] [a] equipment to be removed from organizational spaces for off-site maintenance is sanitized of any CUI.
- [ ] MA.L2-3.7.4 – Media Inspection: Check media containing diagnostic and test programs for malicious code before the media are used in organizational systems.
    - [ ] [a] media containing diagnostic and test programs are checked for malicious code before being used in organizational systems that process, store, or transmit CUI.
- [ ] MA.L2-3.7.5 – Nonlocal Maintenance: Require multifactor authentication to establish nonlocal maintenance sessions via external network connections and terminate such connections when nonlocal maintenance is complete.
    - [ ] [a] MFA is used for nonlocal maintenance sessions
    - [ ] [b] nonlocal maintenance sessions are terminated when complete
- [ ] MA.L2-3.7.6 – Maintenance Personnel: Supervise the maintenance activities of maintenance personnel without required access authorization.
    - [ ] [a] personnel without required authorization are supervised during maintenance

- [ ] 8. Media Protection (MP)
    - [ ] MP.L2-3.8.1 – Media Protection: Protect (i.e., physically control and securely store) system media containing CUI, both paper and digital.
        - [ ] [a] paper media containing CUI is physically controlled;
        - [ ] [b] digital media containing CUI is physically controlled;
        - [ ] [c] paper media containing CUI is securely stored; and
        - [ ] [d] digital media containing CUI is securely stored.
    - [ ] MP.L2-3.8.2 – Media Access: Limit access to CUI on system media to authorized users.
        - [ ] [a] access to CUI on system media is limited to authorized users
    - [ ] MP.L2-3.8.3 – Media Disposal [CUI Data]: Sanitize or destroy system media containing CUI before disposal or release for reuse.
        - [ ] [a] media is sanitized or destroyed before disposal
        - [ ] [b] media is sanitized before release for reuse
    - [ ] MP.L2-3.8.4 – Media Markings: Mark media with necessary CUI markings and distribution limitations.
        - [ ] [a] media containing CUI is marked with applicable CUI markings; and
        - [ ] [b] media containing CUI is marked with distribution limitations.
    - [ ] MP.L2-3.8.5 – Media Accountability: Control access to media containing CUI and maintain accountability for media during transport outside of controlled areas.
        - [ ] [a] access to media is controlled
        - [ ] [b] accountability is maintained during transport outside controlled areas
    - [ ] MP.L2-3.8.6 – Portable Storage Encryption: Implement cryptographic mechanisms to protect the confidentiality of CUI stored on digital media during transport unless otherwise protected by alternative physical safeguards.
        - [ ] [a] CUI on digital media is protected during transport via cryptography or physical safeguards
    - [ ] MP.L2-3.8.7 – Removeable Media: Control the use of removable media on system components.
        - [ ] [a] use of removable media on system components is controlled
    - [ ] MP.L2-3.8.8 – Shared Media: Prohibit the use of portable storage devices when such devices have no identifiable owner.
        - [ ] [a] use of portable storage without an identifiable owner is prohibited

- ☑ MP.L2-3.8.9 – Protect Backups: Protect the confidentiality of backup CUI at storage locations.
  - ☑ [a] confidentiality of backup CUI is protected at storage locations

☐ 9. Personnel Security (PS)

- ☐ PS.L2-3.9.1 – Screen Individuals: Screen individuals prior to authorizing access to organizational systems containing CUI.
  - ☐ [a] individuals are screened prior to authorizing access
- ☐ PS.L2-3.9.2 – Personnel Actions: Ensure that organizational systems containing CUI are protected during and after personnel actions such as terminations and transfers.
  - ☐ [a] a policy for terminating access coincident with personnel actions exists
  - ☐ [b] access/credentials are terminated consistent with personnel actions
  - ☐ [c] the system is protected during and after personnel transfer actions.

☐ 10. Physical Protection (PE)

- ☐ PE.L2-3.10.1 – Limit Physical Access [CUI Data]: Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.
  - ☐ [a] authorized individuals allowed physical access are identified;
  - ☐ [b] physical access to organizational systems is limited to authorized individuals;
  - ☐ [c] physical access to equipment is limited to authorized individuals
  - ☐ [d] physical access to operating environments is limited
- ☑ PE.L2-3.10.2 – Monitor Facility: Protect and monitor the physical facility and support infrastructure for organizational systems.
  - ☑ [a] the physical facility where organizational systems reside is protected;
  - ☑ [b] the support infrastructure for organizational systems is protected;
  - ☑ [c] the physical facility where organizational systems reside is monitored; and
  - ☑ [d] the support infrastructure for organizational systems is monitored.
- ☐ PE.L2-3.10.3 – Escort Visitors [CUI Data]: Escort visitors and monitor visitor activity.
  - ☐ [a] visitors are escorted
  - ☐ [b] visitor activity is monitored
- ☐ PE.L2-3.10.4 – Physical Access Logs [CUI Data]: Maintain audit logs of physical access.
  - ☐ [a] audit logs of physical access are maintained
- ☑ PE.L2-3.10.5 – Manage Physical Access [CUI Data]: Control and manage physical access devices.
  - ☑ [a] physical access devices are identified;
  - ☑ [b] physical access devices are controlled; and
  - ☑ [c] physical access devices are managed.
- ☐ PE.L2-3.10.6 – Alternative Work Sites: Enforce safeguarding measures for CUI at alternate work sites.
  - ☐ [a] safeguarding measures are defined for alternate sites
  - ☐ [b] safeguarding measures are enforced for alternate sites

☐ 11. Risk Assessment (RA)

- ☐ RA.L2-3.11.1 – RIsk Assessments: Periodically assess the risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals, resulting from the operation of organizational systems and the associated processing, storage, or transmission of CUI.
  - ☐ [a] assessment frequency is defined
  - ☐ [b] risks are assessed with the defined frequency

- ☐ RA.L2-3.11.2 – Vulnerability Scan: Scan for vulnerabilities in organizational systems and applications periodically and when new vulnerabilities affecting those systems and applications are identified.
  - ☐ [a] the frequency to scan for vulnerabilities in organizational systems and applications is defined;
  - ☐ [b] vulnerability scans are performed on organizational systems with the defined frequency;
  - ☐ [c] vulnerability scans are performed on applications with the defined frequency;
  - ☐ [d] vulnerability scans are performed on organizational systems when new vulnerabilities are identified; and
  - ☐ [e] vulnerability scans are performed on applications when new vulnerabilities are identified.
- ☐ RA.L2-3.11.3 – Vulnerability Remediation: Remediate vulnerabilities in accordance with risk assessments.
  - ☐ [a] vulnerabilities are identified
  - ☐ [b] vulnerabilities are remediated in accordance with risk assessments

☐ 12. Security Assessment (CA)

- ☐ CA.L2-3.12.1 – Security Control Assessment: Periodically assess the security controls in organizational systems to determine if the controls are effective in their application.
  - ☐ [a] assessment frequency is defined
  - ☐ [b] controls are assessed for effectiveness with that frequency
- ☑ CA.L2-3.12.2 – Operational Plan of Action: Develop and implement plans of action designed to correct deficiencies and reduce or eliminate vulnerabilities in organizational systems.
  - ☑ [a] deficiencies and vulnerabilities to be addressed by the plan of action are identified;
  - ☑ [b] a plan of action is developed to correct identified deficiencies and reduce or eliminate identified vulnerabilities; and
  - ☑ [c] the plan of action is implemented to correct identified deficiencies and reduce or eliminate identified vulnerabilities.
- ☐ CA.L2-3.12.3 – Security Control Monitoring: Monitor security controls on an ongoing basis to ensure the continued effectiveness of the controls.
  - ☐ [a] controls are monitored on an ongoing basis
- ☐ CA.L2-3.12.4 – System Security Plan: Develop, document, and periodically update system security plans that describe system boundaries, system environments of operation, how security requirements are implemented, and the relationships with or connections to other systems.
  - ☐ [a] a system security plan is developed;
  - ☐ [b] the system boundary is described and documented in the system security plan;
  - ☐ [c] the system environment of operation is described and documented in the system security plan;
  - ☐ [d] the security requirements identified and approved by the designated authority as non-applicable are identified;
  - ☐ [e] the method of security requirement implementation is described and documented in the system security plan;
  - ☐ [f] the relationship with or connection to other systems is described and documented in the system security plan;
  - ☐ [g] the frequency to update the system security plan is defined; and
  - ☐ [h] system security plan is updated with the defined frequency.

☐ 13. System and Communications Protection (SC)

- [x] SC.L2-3.13.1 – Boundary Protection [CUI Data]: Monitor, control, and protect communications (i.e., information transmitted or received by organizational systems) at the external boundaries and key internal boundaries of organizational systems.
    - [x] [a] the external system boundary is defined;
    - [x] [b] key internal system boundaries are defined;
    - [x] [c] communications are monitored at the external system boundary;
    - [x] [d] communications are monitored at key internal boundaries;
    - [x] [e] communications are controlled at the external system boundary;
    - [x] [f] communications are controlled at key internal boundaries;
    - [x] [g] communications are protected at the external system boundary; and
    - [x] [h] communications are protected at key internal boundaries.
- [ ] SC.L2-3.13.2 – Security Engineering: Employ architectural designs, software development techniques, and systems engineering principles that promote effective information security within organizational systems.
    - [ ] [a] architectural designs that promote effective information security are identified;
    - [ ] [b] software development techniques that promote effective information security are identified;
    - [ ] [c] systems engineering principles that promote effective information security are identified;
    - [ ] [d] identified architectural designs that promote effective information security are employed;
    - [ ] [e] identified software development techniques that promote effective information security are employed; and
    - [ ] [f] identified systems engineering principles that promote effective information security are employed.
- [ ] SC.L2-3.13.3 – Role Separation: Separate user functionality from system management functionality
    - [ ] [a] user functionality is identified;
    - [ ] [b] system management functionality is identified; and
    - [ ] [c] user functionality is separated from system management functionality.
- [ ] SC.L2-3.13.4 – Shared Resource Control: Prevent unauthorized and unintended information transfer via shared system resources.
    - [ ] [a] unintended information transfer via shared resources is prevented
- [x] SC.L2-3.13.5 – Public-Access System Separation [CUI Data]: Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.
    - [x] [a] publicly accessible components are identified
    - [x] [b] components are separated from internal networks via subnetworks
- [ ] SC.L2-3.13.6 – Network Communication by Exception: Deny network communications traffic by default and allow network communications traffic by exception (i.e., deny all, permit by exception).
    - [ ] [a] traffic is denied by default
    - [ ] [b] traffic is allowed by exception
- [ ] SC.L2-3.13.7 – Split Tunneling: Prevent remote devices from simultaneously establishing non-remote connections with organizational systems and communicating via some other connection to resources in external networks (i.e., split tunneling).
    - [ ] [a] remote devices are prevented from split tunneling
- [ ] SC.L2-3.13.8 – Data in Transit: Implement cryptographic mechanisms to prevent unauthorized disclosure of CUI during transmission unless otherwise protected by alternative physical safeguards.

- [ ] [a] cryptographic mechanisms intended to prevent unauthorized disclosure of CUI are identified;
- [ ] [b] alternative physical safeguards intended to prevent unauthorized disclosure of CUI are identified; and
- [ ] [c] either cryptographic mechanisms or alternative physical safeguards are implemented to prevent unauthorized disclosure of CUI during transmission.

- [ ] SC.L2-3.13.9 – Connections Termination: Terminate network connections associated with communications sessions at the end of the sessions or after a defined period of inactivity.
  - [ ] [a] a period of inactivity to terminate network connections associated with communications sessions is defined;
  - [ ] [b] network connections associated with communications sessions are terminated at the end of the sessions; and
  - [ ] [c] network connections associated with communications sessions are terminated after the defined period of inactivity.
- [ ] SC.L2-3.13.10 – Key Management: Establish and manage cryptographic keys for cryptography employed in organizational systems.
  - [ ] [a] cryptographic keys are established whenever cryptography is employed; and
  - [ ] [b] cryptographic keys are managed whenever cryptography is employed.
- [ ] SC.L2-3.13.11 – CUI Encryption: Employ FIPS-validated cryptography when used to protect the confidentiality of CUI.
  - [ ] [a] FIPS-validated cryptography is used for CUI confidentiality
- [x] SC.L2-3.13.12 – Collaborative Device Control: Prohibit remote activation of collaborative computing devices and provide indication of devices in use to users present at the device.
  - [x] [a] collaborative computing devices are identified;
  - [x] [b] collaborative computing devices provide indication to users of devices in use; and
  - [x] [c] remote activation of collaborative computing devices is prohibited.
- [ ] SC.L2-3.13.13 – Mobile Code: Control and monitor the use of mobile code.
  - [ ] [a] use of mobile code is controlled; and
  - [ ] [b] use of mobile code is monitored.
- [x] SC.L2-3.13.14 – Voice Over Internet Protocol: Control and monitor the use of Voice over Internet Protocol (VoIP) technologies.
  - [x] [a] use of Voice over Internet Protocol (VoIP) technologies is controlled; and
  - [x] [b] use of Voice over Internet Protocol (VoIP) technologies is monitored.
- [x] SC.L2-3.13.15 – Communications Authenticity: Protect the authenticity of communications sessions.
  - [x] [a] authenticity of communications sessions is protected
- [ ] SC.L2-3.13.16 – Data at Rest: Protect the confidentiality of CUI at rest.
  - [ ] [a] confidentiality of CUI at rest is protected

- [ ] 14. System and Information Integrity (SI)
  - [ ] SI.L2-3.14.1 – Flaw Remediation [CUI Data]: Identify, report, and correct system flaws in a timely manner.
    - [ ] [a] the time within which to identify system flaws is specified;
    - [ ] [b] system flaws are identified within the specified time frame;
    - [ ] [c] the time within which to report system flaws is specified;
    - [ ] [d] system flaws are reported within the specified time frame;
    - [ ] [e] the time within which to correct system flaws is specified; and
    - [ ] [f] system flaws are corrected within the specified time frame.

- ☑ SI.L2-3.14.2 – Malicious Code Protection [CUI Data]: Provide protection from malicious code at designated locations within organizational systems.
  - ☑ [a] protection locations are identified
  - ☑ [b] protection is provided at those locations
- ☑ SI.L2-3.14.3 – Security Alerts & Advisories: Monitor system security alerts and advisories and take action in response.
  - ☑ [a] response actions to system security alerts and advisories are identified;
  - ☑ [b] system security alerts and advisories are monitored; and
  - ☑ [c] actions in response to system security alerts and advisories are taken.
- ☐ SI.L2-3.14.4 – Update Malicious Code Protection [CUI Data]: Update malicious code protection mechanisms when new releases are available.
  - ☐ [a] mechanisms are updated when new releases are available
- ☑ SI.L2-3.14.5 – System & File Scanning [CUI Data]: Perform periodic scans of organizational systems and real-time scans of files from external sources as files are downloaded, opened, or executed.
  - ☑ [a] the frequency for malicious code scans is defined;
  - ☑ [b] malicious code scans are performed with the defined frequency; and
  - ☑ [c] real-time malicious code scans of files from external sources as files are downloaded, opened, or executed are performed.
- ☐ SI.L2-3.14.6 – Monitor Communications for Attacks: Monitor organizational systems, including inbound and outbound communications traffic, to detect attacks and indicators of potential attacks.
  - ☐ [a] the system is monitored to detect attacks and indicators of potential attacks;
  - ☐ [b] inbound communications traffic is monitored to detect attacks and indicators of potential attacks; and
  - ☐ [c] outbound communications traffic is monitored to detect attacks and indicators of potential attacks.
- ☐ SI.L2-3.14.7 – Identify Unauthorized Use: Identify unauthorized use of organizational systems.
  - ☐ [a] authorized use is defined
  - ☐ [b] unauthorized use is identified

3. Mitre Att&ck Framework[2]

Threat Modeling with ATT&CK provides a recommended approach that integrates MITRE ATT&CK® – the common language that security operations teams rely upon – into their organization's threat modeling practices. The ATT&CK integration enables cyber defenders to focus on the activity of threat modeling with a clear, consistent understanding of adversary behaviors and tailor defensive investments to mitigate threats related to their systems or environments.

3.1. What are we working on?

This section enables the primary and secondary function(s) of the system to be identified and analyzed. It identifies critical tasks that must be performed for the system to successfully accomplish its function(s) and highlights the resources those critical tasks rely upon.

3.1.1. Assemble your team

3.1.1.1. Gather relevant documentation

Ensure the team familiarizes themselves with relevant documentation of the system under analysis. We want to ensure the team understands the system prior to engaging other stakeholders. Depending on your type of system and the time you have, some documents we recommend reviewing are:

Documents of Interest

- [ ] Information security policies
- [ ] Password policies
- [ ] Employee staffing policies
- [ ] Data classification policies
- [ ] Disaster recovery plans
- [ ] Data backup policies
- [ ] Business continuity plans
- [ ] External drive policies
- [ ] Incident response plans
- [x] Network architecture Network Architecture
- [ ] Remote access policies
- [ ] Network security policy
- [ ] Risk assessment procedures and policies
- [ ] User permission guidelines
- [ ] Allowed applications list
- [ ] Account management policies
- [ ] Security applications list
- [ ] Cloud security policies
- [ ] File storage application list and policies
- [ ] Cloud architecture
- [ ] Inventory procedures
- [ ] Mobile security policies

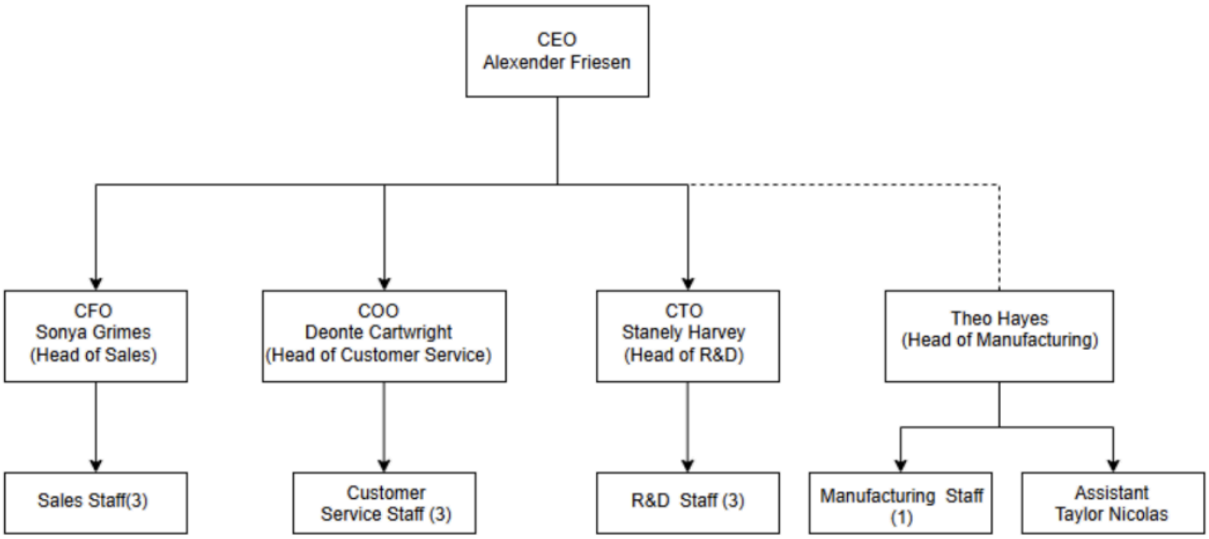
[2] Threat Modeling with ATT&CK v1.0.1
https://center-for-threat-informed-defense.github.io/threat-modeling-with-attack/

3.1.1.2. Identify key stakeholders

These individuals are your subject matter experts who will provide insights into the nature of the assessed system. They can either serve as active members of the assessment team or as points of contact throughout the assessment as needed. You may already know who these individuals are, but there are some techniques that might help you narrow your search for relevant personnel.

Pre-mortem

Imagine a crisis scenario: the assessed system is inoperable; the timeline for project development has broken down; you're unable to provide a key service to your customers, etc. Who do you call? What information do you need?



Sales Staff
- Sales Agent
  - Dexter Morris
  - Lisa Mosciski
  - Olivia (Libby) Justin

Customer Service Staff
- CS Agent
  - Cassandra Reichert
  - Darlene Hintz
  - Waldo Smith

R&D staff
- QA Test Lead
  - Jerald Hill
- Design Lead
  - Josie Ruecker
- Tech Lead
  - Kyla O'Keefe

Manufacturing Staff
- UNKNOWN

Secretary / Greeter
- Triston Skiles

External Security Consultant
- StuDENT LLC

Responsible, Accountable, Consulted, and Informed (RACI) Matrix

A RACI Matrix lets you represent which staff are involved in the operation of the system in question, and their respective impact. A RACI Matrix that ties specific staff to tasks and cyber assets can be developed in tandem with the development of a Mission Impact Assessment.

	CEO	**CFO**	**COO**	**CTO**	**Head of Manufacturing**	**StuDENT LLC**
Finance and Budget approval	A	R	C	C	C	C
Sales and Marketing	A	R	C	I	C	I
Customer Service and Customer Relations	A	C	R	I	C	I
Research and Development	A	C	I	R	I	I
Manufacutring and Assembly	A	C	I	I	R	I
Risk Assessment & Threat Modeling	A	C	C	C	C	R

3.1.2. Mission Decomposition

After conducting your kick-off meeting, it's time to start conducting an analysis of your mission and the systems needed to facilitate it. Drafting this analysis can also be done during your kick-off meeting or over the course of several meetings/discussions with stakeholders, depending on how much time you have. Below are four steps that can guide you through mission and system decomposition. Each step has a series of questions that drive a better understanding of your critical assets.

3.1.2.1. Map the mission objectives

At this stage we want to determine: What is the ultimate purpose of the system? What goal is the system trying to accomplish? It's here that we'll invoke our fictional example device: the Ankle Monitoring Predictor of Stroke (AMPS). This fabricated IoT device is borrowed from MITRE's Playbook for Threat Modeling Medical Devices. In our scenario, this device is meant to be worn by a patient who is at increased risk of experiencing a stroke. By wearing the device throughout the day, the patient and their doctor can monitor for indicators of an imminent stroke via a companion app on the patient's phone and readings uploaded to the AMPS cloud service each day. As a security team evaluating AMPS for its manufacturer, we identified that a core mission objective of AMPS is to collect and share patient health data accurately and securely. Because of the sensitive nature of the health data AMPS collects and shares, which includes location data to guide an emergency response in the event of a stroke, the AMPS device should effectively protect the confidentiality of that data.

Mission Statement

Secure Skies provides on-demand counter-drone capability relying on kamikaze drone interceptors. Working to implement the next-generation system, we strive to eliminate the need for consumable drones and bring innovative technology to the drone industry.

Mission Objectives

- Protection of Intellectual Property (IP)
    - The mission to innovate could be threatened by data exploitation or insider threats. This calls for the protection of data, source code, and design artifacts.
- Integrity of Manufacturing and Continuous Integration/Continuous Deployment (CI/CD) Pipelines
    - To deliver functional drones, the company must secure its CI/CD pipeline tokens and its Computer Numerical Control (CNC) manufacturing workstations.
- Security of Financial Assets and Communications
    - Achieving an IPO requires financial stability. This could be undermined by Business Email Compromise (BEC) and MFA fatigue attacks.
- Resilience of the Supply Chain
    - The mission depends on third-party vendors, such as time-tracking SaaS providers and maintenance contractors, where compromises may lead to SSO credential harvesting and internal network scans

3.1.2.2. Identify Operational Tasks (Cross-Functional Flow Chart)

Next, leverage the knowledge pooled from stakeholders to determine the different operational sub-systems that contribute to the system's primary purpose identified in Step 1. An Analytic Hierarchy Process (AHP) can be used to weigh the importance of different operational systems. Ask yourself, what are the operational tasks that must be executed to perform that function? These are also known as Mission Essential Functions (MEFs). To visualize these MEFs, we recommend using a cross functional flow chart like the one below for the AMPS.

Cross-Functional Flow Chart and CI/CD Architecture
The SecureSkies CI/CD architecture diagram depicts the full software delivery chain from developer workstations on the 192.168.50.0/24 R&D subnet through GitLab source control at gitlab.secureskies.com into the Jenkins automation environment at jenkins.secureskies.com. At the build stage the pipeline bifurcates into two distinct paths — a Docker build and push flow delivering containerized Rust API services to the GCP private registry, and a separate cargo cross-compilation path producing raw ARM firmware binaries deployed directly to drone hardware via the skycore artifact store, explicitly excluding firmware from containerization.

Cross-Functional Flow Chart.png

3.1.3. System Decomposition

3.1.3.1. Develop a Data Flow Diagram (DFD) of your system

There are multiple ways to design a DFD, but we recommend the DFD3 standard. Begin by answering the following questions:

- What are the known components of the system?
- What components within your system connect to each other?
- What known third-party connections exist outside of your system's control?

From these questions, start to draw your diagram and gradually add additional components and sub-systems to the DFD depending on scope and time. Start at a high level and work your way down as seen in the below AMPS examples. Ultimately, these datapoints should come together to form a comprehensive map of your system.

Data Flow Diagram

Data Flow Diagram

3.1.3.2. Determine which system functions are associated with distinct operational tasks

With the DFD of your system in hand, you can then link the system's operational tasks to specific system functions. When executing a specific task, what parts of the system are utilized? These include both assets and data flows between systems.

System Mapping

Mission Objective	Operational Task	System Function
Protection of Intellectual Property (IP)	Develop and synchronize flight control algorithms	Internal Git repositories (flight-control-core, telemetry-stack) and R&D workstation sync
Protect proprietary drone technology IP	Build and deploy internal API services	Cloud CI/CD pipeline and internal container registry (api-internal images)
Integrity of Manufacturing and Continuous Integration/Continuous Deployment (CI/CD) Pipelines	Transfer design blueprints to fabrication hardware	OctoPrint server orchestration and manual USB data transfers to CNC/3D Printers
Ensure operational stability and financial health	Process employee payroll and direct deposits	Internal Payroll portal (Web Server) and Database Server transaction processing
Resilience of the Supply Chain	Cloud API	External Services

3.1.4. Identification of critical assets

Now that you've done mission and system decomposition, you should have a much better idea of which system functions facilitate operational tasks that enable your mission. Using your DFD and the matrix from Part 7, you can now identify critical assets. Ask yourself the following questions:

- Which system assets and dataflows are shared by multiple processes?
- What assets and data flows enable different system functions?
- How does the failure of each operational task impact the system's mission objectives?
- What are downstream effects of taking each cyber asset offline?

Critical Assets

- High Impact, High Exposure
    - Firewall/VPN Gateway
    - Domain Controller
    - NextCloud (File Collaboration Platform)
    - Customer Trust
    - Brand Reputation
- High Impact. Medium Exposure
    - Production/Application Servers (On-Prem/VM Hosts)
    - File/Storage Server (if separate)
    - Network Infrastructure (Switches/Routers/Wi-Fi)
    - Access Control Card Readers
    - Intellectual Property (Design Files + R&D Knowledge)

    - Data Flow: External Services to Router
    - Data Flow: Communications to and from Database and Mail Server
    - Data Flow: Communications between R&D and Manufacturing Departments
- Medium Impact, High Exposure
    - Employee Workstations (Desktops/Laptops)

3.1.5. Open Source Intelligence Report

The Open Source Intelligence (OSINT) report provides a detailed assessment of the organization's public-facing vulnerabilities and digital footprint using passive reconnaissance techniques. This report serves as a critical artifact for the broader cyber risk modeling engagement, directly informing the risk probability estimates used in the FAIR Monte Carlo model by identifying exposures across six distinct categories: digital footprint, credential exposure, CVE exposure, job posting disclosures, social media exposure, and sector-specific threat intelligence. Key findings highlighted in the report include CRITICAL severity risks such as an unauthenticated OctoPrint server exposed on port 5000, seven corporate email addresses—including the CEO's—found in breach databases, and active targeting by state-sponsored actors like Volt Typhoon who focus on drone manufacturers seeking Department of War contracts. By documenting these publicly accessible data points, the report establishes a verifiable foundation for understanding how an adversary performs reconnaissance and achieves initial access into the Secure Skies environment.

SecureSkies_OSINT_Report.docx

3.1.6. Asset Classification

The Secure Skies Asset Classification and Criticality Analysis serves as a core artifact for organizing the company's systems, services, and intangible concerns into a structured model for risk evaluation and remediation planning. By evaluating assets—ranging from technical identity infrastructure like the Domain Controller to high-value intangibles such as proprietary drone designs and R&D knowledge—the matrix identifies which components are most vital to the corporate mission and would cause the greatest business impact if compromised. This analysis directly informs the prioritization of security controls, ensuring that remediation strategies are grounded in business context rather than technical issues alone to support Secure Skies' path toward CMMC Level 2 compliance.

Asset Classification

3.1.7. Software Development and Operations Asset List

The Secure Skies Software Development and Operations Asset List provides a detailed inventory of the critical systems and data assets comprising the company's DevSecOps pipeline, including the Jenkins CI/CD automation environment and GitLab source code repositories. By mapping these assets to specific MITRE ATT&CK techniques, the list identifies vulnerabilities with CRITICAL pre-control severity, such as supply chain compromise (T1195.002) and credential exposure in files (T1552.001)—risks that were previously actualized in the SS10 incident. The document functions as a technical roadmap for risk mitigation, prescribing NIST-aligned implementation controls like secret scanning, binary authorization, and short-lived authentication tokens to reduce residual risk to MEDIUM. Ultimately, this systematic classification ensures that the development of Secure Skies' proprietary drone technology is protected by a verifiable security baseline essential for achieving CMMC Level 2 compliance.

SecureSkies_ Software Development and Operations Asset List.xlsx

3.1.8. Concept Map

The Concept Map is a foundational systems-thinking visualization designed to provide a holistic view of the organization's cybersecurity posture and the interdependencies of its critical assets. By applying the

DSRP framework—which systematically analyzes Distinctions, Systems, Relationships, and Perspectives—this map translates complex technical data from incident reports and network logs into a visible working model of the entire corporate ecosystem. It illustrates the vital connections between technical assets (such as the OctoPrint server and proprietary source code), business processes, and human actors ranging from R&D engineers to C-suite executives. Ultimately, this artifact serves as a strategic baseline for identifying high-value data flows and prioritizing the remediation steps necessary for Secure Skies to achieve CMMC Level 2 compliance and secure its target government contracts.

Concept Map

3.1.9. Master Evidence Log

The Secure Skies Master Evidence Log is a comprehensive repository that systematically catalogs confirmed security incidents and data exposures discovered during the investigative process, providing a structured foundation for technical risk analysis. By documenting critical details such as impacted systems, involved personnel, and specific MITRE ATT&CK techniques, the log translates raw event data from historical breaches—including the exfiltration of 14 GB of source code (SS2), a $27,450 payroll redirection (SS1), and numerous third-party supply chain failures—into actionable risk scenarios. This artifact serves as a vital tool for identifying high-value asset interdependencies and prioritizing the remediation efforts necessary to address systemic vulnerabilities and achieve CMMC Level 2 compliance.

Master Evidence Log

3.2. What could go wrong?

The process outlined in Question 1 derives critical assets within a particular system. In Question 2, we identify and prioritize threats to those assets. MITRE ATT&CK® will serve as the framework through which we map and discuss threats to our system. While our analysis will go beyond the tactics, techniques, and procedures (TTPs) found within ATT&CK, its value as a language for detailing adversary behaviors makes it a central part of our approach. ATT&CK's widespread use within the CTI community and its comprehensive classification system allow us to draw upon existing threat data while still integrating additional threats not yet captured in public reporting.

3.2.1. STRIDE

The STRIDE analysis reveals that Secure Skies is highly susceptible to credential-based attacks and external service exploitation. The lack of DMARC enforcement, unauthenticated manufacturing servers, and reliance on vendor default credentials create a large attack surface. Furthermore, the company is an active targeting priority for nation-state actors like Volt Typhoon, who specifically focus on drone manufacturers seeking Department of War contracts.

STRIDE Framework

3.2.2. FAIR

The FAIR framework is used to decompose risk into discrete, measurable factors to determine the expected annual financial loss. At Secure Skies, 12 specific risk scenarios—such as source code theft and ransomware—have been fully modeled using this approach.

- Risk Definition: Risk is calculated as the product of Loss Event Frequency (LEF) and Loss Magnitude (LM).
- Loss Event Frequency (LEF): This is determined by multiplying Threat Event Frequency (how often an attack is attempted) by Vulnerability (the probability an attack succeeds given current controls).

- Loss Magnitude (LM): This is the sum of Primary Losses (direct costs like data recovery or fraud) and Secondary Losses (downstream costs like CMMC contract loss or regulatory fines).
- Input Distributions: Rather than using single numbers, FAIR uses distributions (such as PERT or Log-normal) to account for uncertainty in pre-audit environments.
- CMMC Alignment: This quantitative approach satisfies RA.3.144, which requires risk assessments to be consistent with recognized risk frameworks.

Refer to Dashboard for more information

3.2.3. STIX

The STIX Threat Intelligence tab provides a structured, industry-standard view of the cyber threat landscape specific to the drone and defense manufacturing sector. Utilizing the STIX 2.1 framework, the dashboard maps known threat actors such as Volt Typhoon (PRC-linked) and Fancy Bear (Russian GRU) directly to the tactics, techniques, and procedures (TTPs) they employ. This tab visualizes the relationship between these actors and Secure Skies' specific assets, using MITRE ATT&CK codes to correlate external threat data with the organization's 10 confirmed internal security incidents.

This intelligence-led approach is a critical component of achieving CMMC 2.0 Level 2 compliance, particularly within the Risk Assessment (RA.3.144) domain, which requires organizations to use threat intelligence to inform their security posture. By citing authoritative sources like CISA advisories (notably AA24-038A regarding threats to UAV manufacturers), the dashboard demonstrates a mature, threat-informed defensive strategy. This functionality provides the documented evidence needed for C3PAO assessors to verify that Secure Skies is actively monitoring and defending against sector-specific adversaries.

Refer to Dashboard for more information

3.2.4. Monte Carlo Simulation

The Monte Carlo simulation takes the FAIR input distributions and runs 10,000 iterations to predict the range of all possible loss outcomes for the organization.

- Simulation Process: In each of the 10,000 runs, the model randomly draws a value from the defined FAIR distributions to calculate a potential Annualized Loss Expectancy (ALE).
- The Resulting Histogram: The aggregate of these iterations is displayed as a histogram, showing the probability of different loss levels.
- Expected ALE: The mean of this distribution is the reported ALE figure used throughout the dashboard, currently totaling approximately $3.97 million per year for Secure Skies.
- Confidence Bands: The analysis provides 5th–95th percentile confidence bands, offering a best-case and worst-case financial outlook rather than a single fixed point.
- Tail Risk Identification: The simulation specifically identifies "black swan" or 99th-percentile events, such as a $20.4 million loss scenario that could be existential for the company.
- Decision Support: These simulations justify the ROI of proposed security controls by showing exactly how much they "shift the curve" toward lower financial exposure.

SecureSkies FAIR Based Monte Carlo Analysis.xlsx

3.3. What are we going to do about it?

The Remediation Roadmap for Secure Skies is a structured, 18-month action plan designed to transition the organization from its current 24% compliance state to approximately 95% CMMC Level 2 readiness. The strategy prioritizes security investments based on their Return on Mitigation (ROM), ensuring that the most cost-effective and highest-impact controls are deployed first to reduce the organization's $3.97 million Annualized Loss Expectancy (ALE). This phased approach allows Secure Skies to capture over

60% of its total risk reduction within the first few months while managing a total implementation budget of approximately $302,000.

The implementation begins with Phase 1 (Months 1–3), which focuses on "Quick Wins" and foundational CMMC documentation. Immediate zero-cost actions include rotating exposed credentials for the VyOS router and AD accounts, disabling USB ports on CNC workstations to prevent malware like SS8, and remediating public cloud buckets. These are followed by the deployment of phishing-resistant Multi-Factor Authentication (MFA) and the drafting of the System Security Plan (SSP), which is a mandatory prerequisite for any formal DoD assessment.

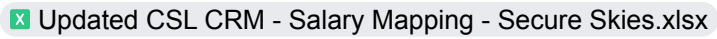
Subsequent stages build upon this foundation to address structural and strategic gaps. Phase 2 (Months 4–9) focuses on technical infrastructure, including network segmentation, EDR deployment, and SIEM/log management to satisfy core audit and accountability requirements. The final stage, Phase 3 (Months 10–18), completes the journey by finalizing governance documentation, implementing supply chain controls, and conducting formal internal assessments. This strategic ordering ensures that by the time Secure Skies engages a C3PAO for a third-party audit, all 110 NIST SP 800-171 practices are implemented and backed by documented evidence

3.3.1. Post Implementation Controls CI/CD Diagram

The SecureSkies DevSecOps pipeline has been updated to implement three security controls directly within the CI/CD delivery chain addressing the vulnerabilities identified. A Secret Scanner is deployed at the merge-to-main gate, intercepting credential exposure at the earliest possible pipeline stage before any build artifact is produced — directly targeting T1552.001. A Dependency Scanner powered by JFrog Xray evaluates all crates.io dependencies declared in cargo.toml against known vulnerability advisories before source code enters the build stage, addressing the T1195.001 supply chain dependency risk introduced by the Rust open source ecosystem. Static Application Security Testing via SonarQube is integrated into the Build (cargo) stage, analyzing source code for security weaknesses.


Implemented-Controls-CICD-Pipeline.drawio.png

3.3.2. Additional Documents for Reference


Updated CSL CRM - Salary Mapping - Secure Skies.xlsx

Refer to Dashboard for more information

4. Dashboard

This guide explains every tab of the Secure Skies Cyber Risk Intelligence Dashboard, a comprehensive platform designed to help Secure Skies achieve CMMC 2.0 Level 2 certification. It provides a detailed breakdown of the dashboard's methodology—integrating real-world incident data with financial risk quantification via the FAIR framework—to create a clear, 18-month roadmap for improving security controls and meeting Department of Defense compliance requirements.

You can access the full documentation here: secure_skies_dashboard_guide.docx

You can view the dashboard here: http://nexuvius.com/CRM_dashboard/